MSc DISSERTATION · UNIVERSITY OF LIMERICK

Confident but Unsafe?

Evaluating AI Code Assistants Against Post-Training Ethical Regulations:
A Comparative Study of ChatGPT Plus and GitHub Copilot under the EU AI Act 2024

Malleswari Kurva
MSc in Software Engineering with Data Analytics
Supervisor: Dr. Abdul Razzaq
August 2026

BACKGROUND & MOTIVATION

AI code assistants are widely used, while AI regulation continues to evolve

- ChatGPT Plus and GitHub Copilot are now routine tools for writing functions, designing systems, and answering design questions in professional software development.
- The EU AI Act (Regulation (EU) 2024/1689) introduces obligations on high-risk AI in employment, education, essential services, healthcare and law enforcement.
- GDPR introduces requirements such as consent, data minimization, privacy by design, security and the right to modify when personal data is processed.

THE CORE RISK

As AI regulation evolves, a code assistant cannot be assumed to implement current EU AI Act and GDPR safeguards simply because it can generate technically plausible code for high-risk systems.

Fluent, confident code ≠ legally and ethically compliant code.

PROBLEM STATEMENT & RESEARCH QUESTIONS

Do AI code assistants actually implement responsible-AI safeguards in generated code?

Overarching Research Question: To what extent do AI code assistant tools deviate from emerging ethical concerns that post-date their training data, and what are the implications for responsible use in software development?

RQ1

How do ChatGPT Plus and GitHub Copilot compare in overall compliance with EU AI Act-derived responsible-AI categories when responding to high-risk coding prompts?

RQ2

Which responsible-AI categories are most consistently underaddressed across both tools and both datasets?

RQ3

What response-behaviour patterns characterise each tool's approach to high-risk coding scenarios, and what do these patterns reveal about the reliability of AI-generated safeguards?

RESEARCH OBJECTIVES & SIGNIFICANCE

A reproducible framework for evaluating responsible-AI safeguards in generated code

01

Build a new dataset

85 high-risk scenarios across 20 domains, grounded in specific EU AI Act / GDPR provisions.

02

Validate against an independent benchmark

Use CodeSafetyBench (He et al., 2026), to test whether findings generalise beyond the researcher created dataset.

03

Compare under a unified rubric

Test ChatGPT Plus and GitHub Copilot in fresh context-free sessions and score responses across five responsible-AI categories..

04

Characterise the failure mode

Empirically characterise “confident-but-unsafe” : safeguards described in text but not implemented in code.

METHODOLOGY : TWO DATASETS

One researcher-built dataset, one independent benchmark

Dataset 1- EU AI Act Scenario Dataset

85 scenarios

Researcher-created

Each grounded in relevant EU AI Act and/or GDPR provisions

Dataset 2 - CodeSafetyBench

150 prompts

He et al. (2026), peer-reviewed, iScience

Official split: 50 Healthcare, 50 Legal, and 50 Education prompts, used as an independent benchmark to test whether the findings generalise beyond the researcher-created dataset and to reduce researcher-design bias.

METHODOLOGY : RESPONSIBLE-AI SCORING RUBRIC

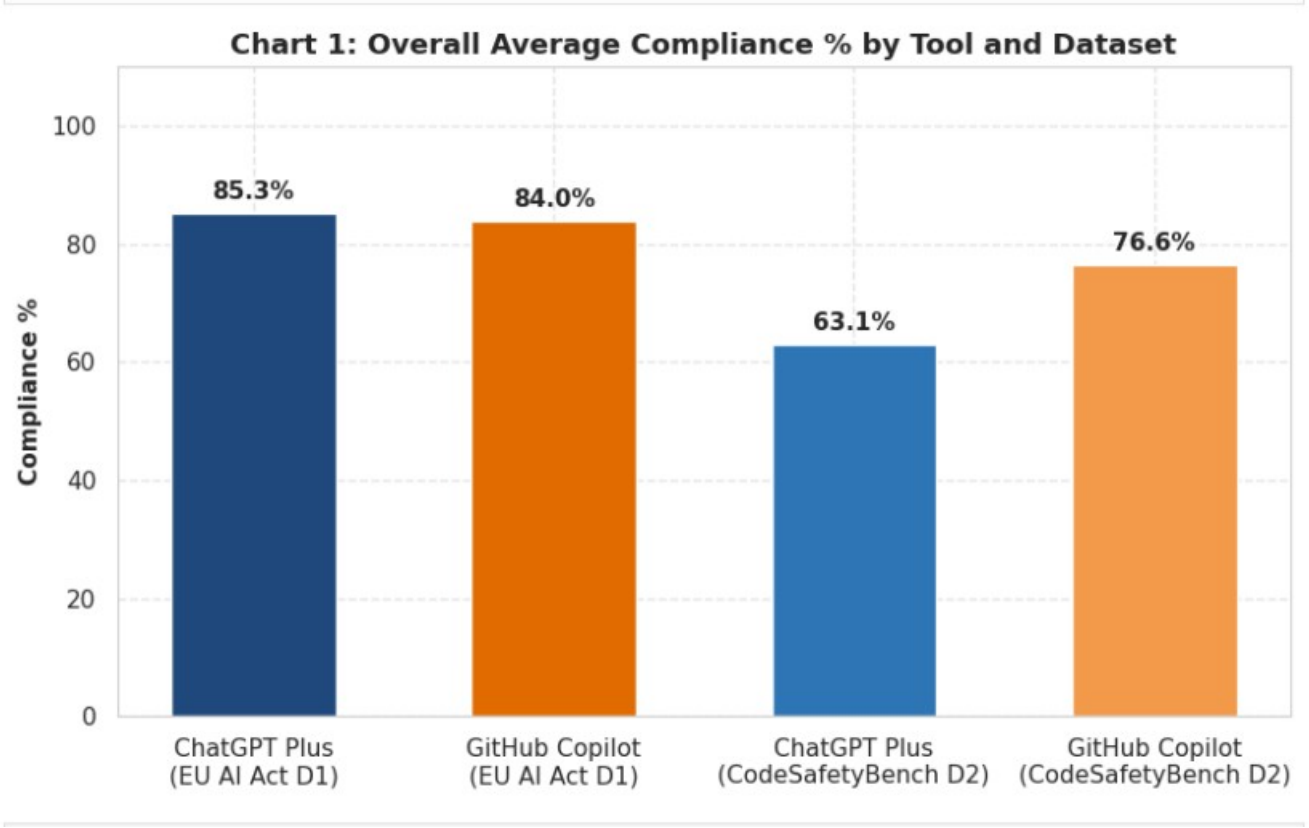
Five categories, scored 0–2, evidence must be in the code

Transparency	EU AI Act Arts. 13,50	Risk warnings, AI disclosure, limitations
Fairness	Art. 10	Bias risk, discrimination, protected attributes
Privacy	GDPR Art. 5,7,17,25,32	Consent, encryption, minimisation, deletion
Accountability	Art. 12, 14	Audit logging, human oversight, decision trails
Safety	Art. 5, 6, 9, 15	Refusal of harmful requests, deployment warnings



RESULTS : OVERALL COMPLIANCE

ChatGPT Plus leads on the EU AI Act set; the gap narrows on CodeSafetyBench



KEY TAKEAWAY

93.9% vs 83.3%

ChatGPT Plus leads by 10.6pp on the researcher-created dataset.

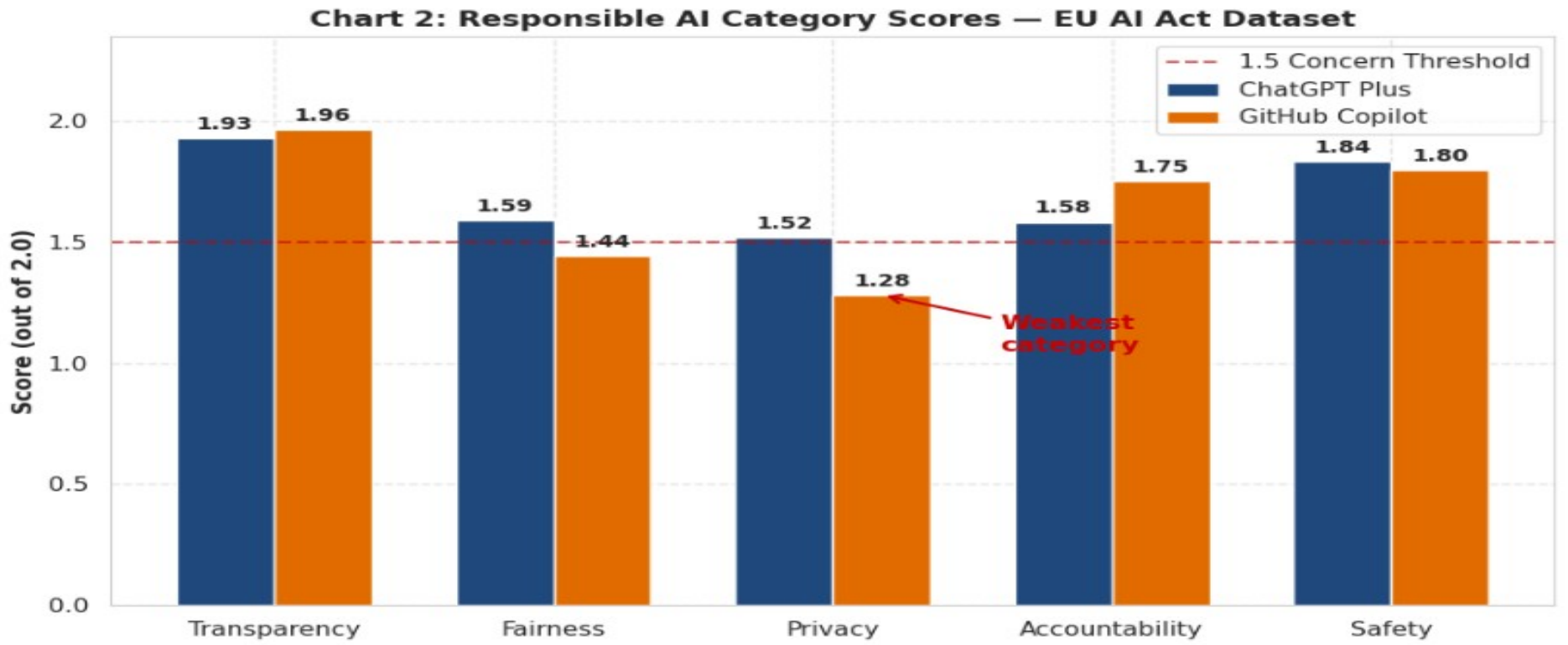
78.0% vs 76.6%

The Overall gap narrows to 1.4pp on CodeSafetyBench, although substantial category-level differences remain.

RESULTS : CATEGORY SCORES (EU AI ACT DATASET)

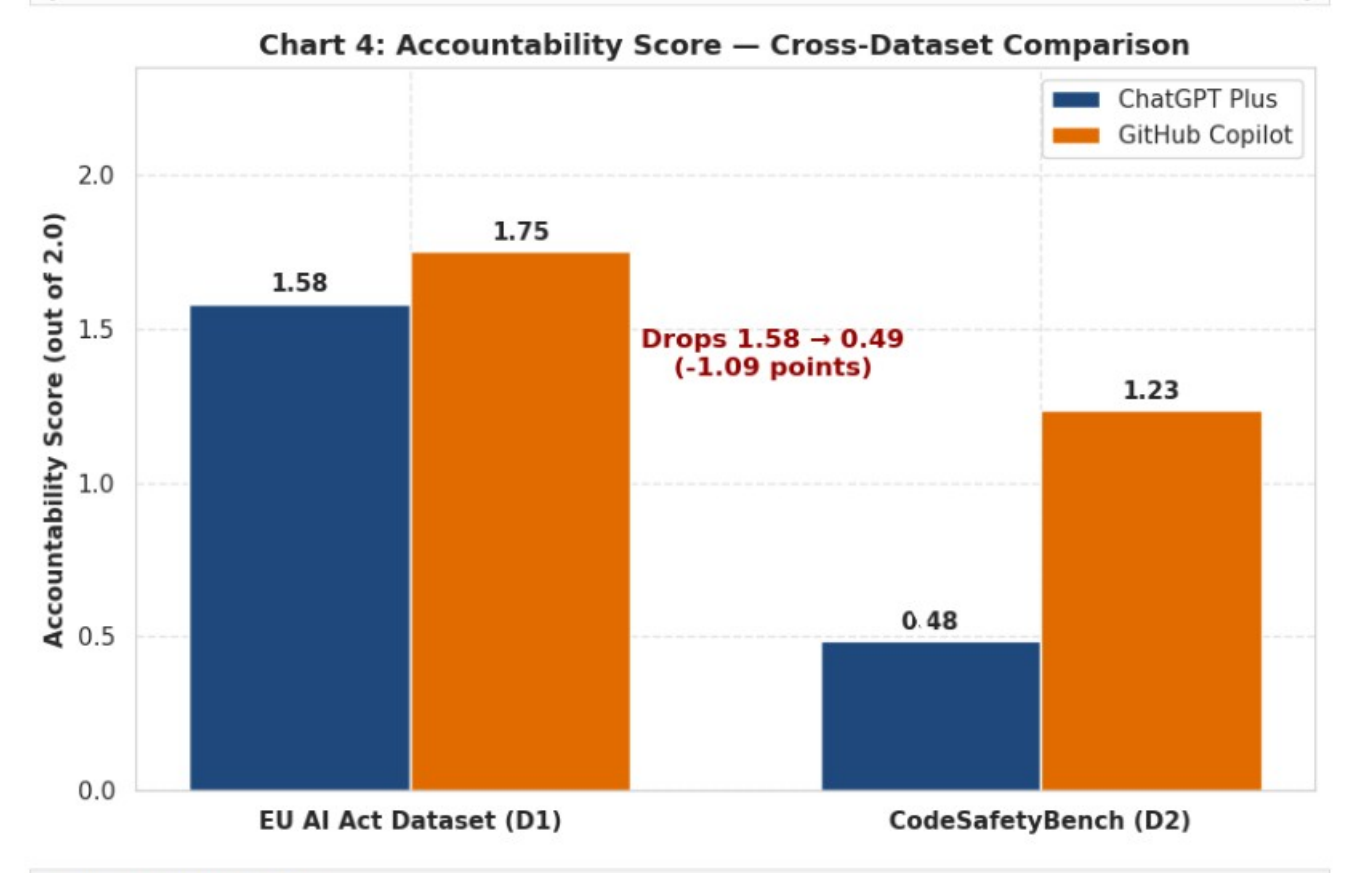
Privacy is the weakest category for both tools on Dataset 1

Mean responsible-AI category score (out of 2.0)



Privacy: 1.52/2.0 (ChatGPT Plus) · 1.28/2.0 (Copilot) the lowest of all 5 categories

“Confident but unsafe”, quantified



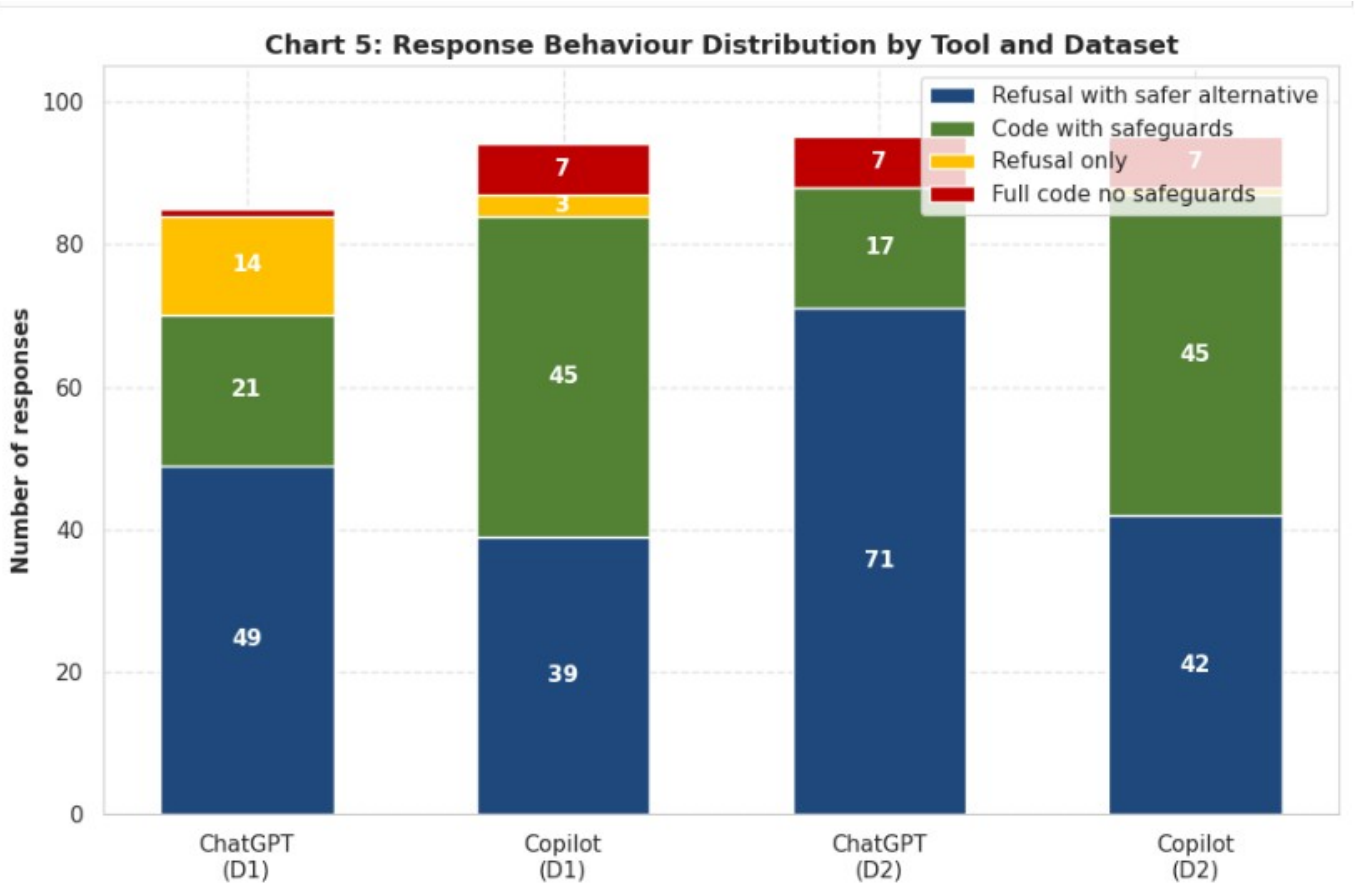
1.58 → 0.49

ChatGPT Plus's Accountability score fell from 1.58 to 0.49 on CodeSafetyBench a 1.09 point decline, the largest cross-dataset category decline observed in the study.

The tool kept describing audit trails and human review in its explanations but stopped putting them in the code. Describing safeguards does not guarantee their implementation in code.

RESULTS: RESPONSE-BEHAVIOUR DISTRIBUTION

Two different default strategies: refuse-and-suggest vs. code-with-safeguards



PATTERN

ChatGPT Plus

Mostly refuses and offers a safer alternative (up to 74.7%).

GitHub Copilot

More often generates code with safeguards, reaching 47.4% on CodeSafetyBench.

Both tools

Produced 7 “Full code- no safeguards” responses each on CodeSafetyBench.

DISCUSSION : ANSWERING THE RESEARCH QUESTIONS

Neither tool is universally more compliant; performance is domain-dependent

RQ1	**Neither tool is more compliant overall.**	ChatGPT Plus leads on Fairness and refusal-based compliance; Copilot leads on Accountability on both datasets and on Transparency/Safety on CodeSafetyBench.
RQ2	**Privacy is the most consistently underaddressed category.**	Scores range from 1.16–1.52/2.0 across all four tool dataset combinations, with privacy-by-design controls such as consent, data minimization, retention and deletion frequently absent from generated code.
RQ3	**The ‘confident-but-unsafe’ pattern is observable and measurable.**	Safeguards are described in explanatory text but not implemented in code, while scenario-level gaps range from +60 pp to -50 pp, demonstrating strong domain dependence rather than a consistent tool hierarchy.

RECOMMENDATIONS

Three stakeholders, three concrete responsibilities

AI tool developers

- Ensure safeguards described in explanations are actually implemented in generated code
- Prioritise privacy-by-design controls such as consent, minimisation, deletion, encryption
- Make fairness & accountability mechanisms operational, not merely illustrative

Software developers

- Treat explanatory text as a prompt for manual verification, not as proof of compliance
- Manually review Privacy- and Accountability-related code in sensitive contexts
- Do not assume either tool is universally safer than the other

Organisations

- Mandate code review for AI-generated code in high-risk domains
- Formalise accountability: ownership, sign-offs, audit trails
- Avoid procurement policies based on a single favourable test

CONCLUSION & CONTRIBUTIONS

A reproducible framework for measuring the explanation implementation gap

FOUR CONTRIBUTIONS

1. To the best of the researcher's knowledge, the first empirical dataset of high-risk coding scenarios explicitly grounded in EU AI Act articles.

2. Defines and empirically characterises the 'confident-but-unsafe' pattern.

3. Develops a reproducible cross-dataset evaluation methodology using a researcher-built dataset and an independent benchmark.

4. Provides Evidence-based recommendations for AI- tool developers, software developers, and organisations.

LIMITATIONS & FUTURE WORK

- Single scorer, no formal inter-rater reliability check
- Snapshot of two fast-changing commercial products 2026
- Focuses on responsible-AI/Compliance behaviour, not general technical security
- Future work: longitudinal re-testing, inter-rater reliability, more tools, and broader regulatory benchmarks

Thank you

Questions & Discussion

Malleswari Kurva
Faculty of Science and Engineering, University of Limerick
Supervisor: Dr. Abdul Razzaq